

Access Management

Purpose

This policy ensures only those that need access to sensitive data are granted it. This guidelines purpose is to establish an outline of how access should be granted and how to maintain access based on the duties of the employee. These guidelines will prevent unauthorized access to sensitive material and ensure the confidentiality of customers' data while protecting the organization from sanctions and reputational harm.

Scope

These guidelines apply to all employees and management that oversees access permissions.

Safeguards

- Establish role based access control. Only employees needing access to sensitive data will be granted rights.
- Formal policy outlining access control rules, including RBAC.
- A defined process for authorizing, recording, and communicating access changes.
- Review logical and physical access privileges periodically and whenever someone changes roles or leaves the organization, and promptly rescind privileges that are no longer needed.
- Define and implement a user access provisioning process which authorizes, records, and communicates access changes to data and assets.
- De-provision or modify access of movers/leavers or system identity changes in a timely manner.
- Access to sensitive data, including cardholder data and customer PII/SPII, is denied by default and granted only when a specific business need is identified and approved.

Sanctions

Non-compliance with these guidelines exposes the organization to violations of PCI DSS Requirement 7 which may result in regulatory penalties, increased transaction fees, or loss of card processing privileges. Payment card brands may impose fines ranging from \$5,000 to \$100,000 per month until the issue is remediated. These actions would also cause notable reputational damage to the organization. Non-compliance will also trigger a review of management's access-granting procedures and controls.